

Resposta a Incidentes de Segurança

Versao:	1.0
Data:	Maio de 2026
Classificacao:	Interno - Confidencial
Empresa:	[NOME_DA_EMPRESA]

Resposta a Incidentes de Segurança

[NOME_DA_EMPRESA]

Versão: 1.0 · Maio de 2026

Classificação: Interno — Restrito

Sumário

- Objetivo
- Definições e Classificação
- Equipe de Resposta
- Processo de Resposta
- Notificação a Clientes e ANPD
- Post-Mortem
- Testes e Simulações

1. Objetivo

Este documento define o processo estruturado de identificação, contenção, erradicação, recuperação e comunicação de incidentes de segurança da informação na [NOME_DA_EMPRESA].

O objetivo é minimizar o impacto de incidentes, proteger os dados de clientes e titulares, cumprir obrigações legais de notificação e aprender continuamente para prevenir recorrências.

2. Definições e Classificação

O que é um Incidente de Segurança

Evento que resulta — ou pode resultar — em:

- Acesso não autorizado a dados pessoais ou sistemas
- Perda, destruição, modificação ou divulgação indevida de dados
- Comprometimento da disponibilidade, integridade ou confidencialidade de sistemas
- Violação de políticas de segurança

Classificação de Severidade

Nível	Critério	Exemplos
Crítico	Violação de dados pessoais confirmada; siste	Acesso não autorizado a prontuários, ransomwa
Alto	Suspeita fundada de violação; funcionalidade	Tentativa de invasão detectada, credencial ad
Médio	Anomalia de segurança sem impacto confirm	Tentativas de brute force bloqueadas, dependê
Baixo	Evento de segurança sem impacto operacion	Log de acesso anômalo sem impacto, phishing b

3. Equipe de Resposta a Incidentes

Papel	Responsável	Contato
Coordenador de Resposta	João Menegucci (CEO)	[TELEFONE]
Responsável Técnico	Jefferson Mattoso (Infra)	A definir
Comunicação com Clientes	Luana Bonfim (Suporte)	A definir
Consultor Jurídico	A contratar	A definir

4. Processo de Resposta

Fase 1 — Identificação e Alerta (t=0)

Objetivo: Detectar e confirmar o incidente.

Fontes de detecção:

- Alertas de monitoramento automatizado
- Reporte de colaborador interno
- Reporte de cliente ou usuário externo
- Varredura de segurança

Ações:

- Quem detecta o incidente aciona imediatamente o Diretor de Infraestrutura e o CEO (via telefone em casos críticos)
- Registro inicial do incidente: data/hora, natureza, quem detectou, sistemas potencialmente afetados
- Classificação preliminar de severidade

Tempo máximo: Alerta ao CEO e Infraestrutura em até 15 minutos da identificação.

Fase 2 — Contenção (t=0 + até 1h para Crítico)

Objetivo: Limitar o alcance do incidente e impedir propagação.

Ações possíveis:

- Isolamento de sistema comprometido (desconexão de rede)
- Revogação de credenciais comprometidas
- Bloqueio de IPs maliciosos
- Ativação de ambiente de contingência
- Suspensão temporária de funcionalidades afetadas

Decisão de contenção: CEO + Diretor de Infraestrutura

Fase 3 — Investigação e Análise (paralela à contenção)

Objetivo: Entender o que aconteceu, como e qual o impacto.

Ações:

- Análise de logs de acesso e sistema
 - Identificação da origem do incidente
 - Mapeamento dos dados e sistemas afetados
 - Determinação se houve acesso, exfiltração ou alteração de dados pessoais
 - Preservação de evidências (logs, dumps) para análise forense
-

Fase 4 — Erradicação

Objetivo: Eliminar a causa raiz do incidente.

Ações:

- Remoção de malware ou código malicioso
 - Aplicação de patches e atualizações de segurança
 - Correção de configurações vulneráveis
 - Revogação e reemissão de credenciais afetadas
 - Auditoria de acessos após erradicação
-

Fase 5 — Recuperação

Objetivo: Restaurar a operação normal com segurança.

Ações:

- Restauração de sistemas a partir de backup limpo (quando necessário)
 - Validação de integridade dos dados restaurados
-

- Retorno progressivo à operação normal
- Monitoramento intensivo pós-recuperação (mínimo 72h)

Fase 6 — Comunicação e Notificação

(Detalhado na seção 5)

Fase 7 — Post-Mortem e Lições Aprendidas

(Detalhado na seção 6)

5. Notificação a Clientes e ANPD

Notificação ao Cliente

Quando: Sempre que o incidente envolver dados do cliente ou impactar sua operação.

Prazo: Comunicação inicial em até 2 horas para incidentes críticos.

Conteúdo da comunicação:

- Natureza do incidente (sem detalhes que possam comprometer a investigação)
- Dados ou sistemas potencialmente afetados
- Medidas de contenção já adotadas
- Próximos passos e prazo de atualização

Notificação à ANPD

A LGPD (Art. 48) exige que o Controlador notifique a Autoridade Nacional de Proteção de Dados (ANPD) em caso de incidente que possa acarretar risco ou dano relevante aos titulares.

Prazo: Em prazo razoável, conforme regulamentação da ANPD (referência: 72 horas após conhecimento do incidente com dados pessoais).

Responsável pela notificação: CEO (como responsável da empresa)

Conteúdo mínimo da notificação à ANPD:

- Descrição dos dados pessoais afetados
 - Número de titulares envolvidos (estimativa)
 - Medidas tomadas para mitigar os riscos
 - Contato do Encarregado de Dados
-

6. Post-Mortem

Para todos os incidentes de nível Crítico e Alto, deve ser elaborado um relatório de post-mortem em até 5 dias úteis após a resolução, contendo:

- Cronologia: linha do tempo do incidente
- Causa raiz: o que originou o incidente
- Impacto: dados e sistemas afetados, estimativa de exposição
- Resposta: avaliação da eficácia da resposta
- Lições aprendidas: o que funcionou e o que falhou
- Ações corretivas: medidas preventivas com responsável e prazo

O relatório é produzido pelo CEO e Infraestrutura, revisado internamente e compartilhado com o cliente afetado quando relevante.

7. Testes e Simulações

O plano de resposta a incidentes deve ser testado:

- Anualmente: simulação de incidente crítico (tabletop exercise)
 - Após cada incidente relevante: revisão e atualização do processo
 - Após mudanças de infraestrutura: validação dos processos de detecção e contenção
-

[NOME_DA_EMPRESA] · [NOME_FINAL_DO_PRODUTO] · Resposta a Incidentes v1.0

Classificação: Interno — Restrito · Maio de 2026